

cflux ERP – Sicherheitskonzept

Version: 1.0 (Entwurf)
Stand: März 2026
Autor: Matthias Püski, IT-Spezialist – Aquist Schweiz GmbH
Klassifizierung: Intern / Vertraulich

1. Einleitung und Geltungsbereich

Dieses Sicherheitskonzept beschreibt die technischen und organisatorischen Maßnahmen zum Schutz der cflux-Plattform sowie der darin verarbeiteten Daten. cflux ist ein ERP-System spezialisiert auf Environment, Health & Safety (EHS), das ArG-konforme Prozesse für Unternehmen in der Schweiz und Deutschland abbildet.

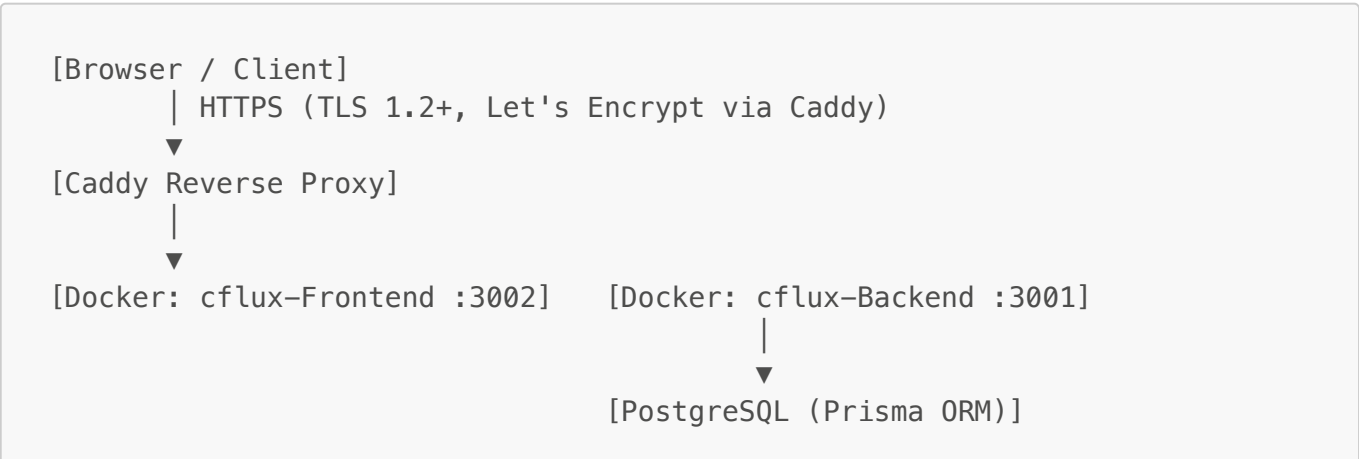
Schutzziele

Schutzziel	Bedeutung für cflux
Integrität	Höchste Priorität: EHS-Dokumente, Prüfprotokolle und LOTOTO-Nachweise dürfen nicht unbemerkt manipulierbar sein. Nachweispflicht gegenüber Behörden.
Verfügbarkeit	Hoch: Ausfall während laufender Inspektionen oder Gefährdungsbeurteilungen ist kritisch.
Vertraulichkeit	Mittel-hoch: Personenbezogene Daten, Unfallberichte und interne Prozessdaten sind schützenswert.

Geltungsbereich

- cflux-Backend (Node.js/Express, PostgreSQL, Prisma)
- cflux-Frontend (React/TypeScript)
- Infrastruktur (Docker, Caddy, Hetzner-Server)
- Testumgebung und Produktionsumgebung (getrennt)

2. Systemarchitektur (Sicherheitsrelevant)



Trennung Umgebungen:

- Produktionsumgebung und Testumgebung laufen als separate Docker-Instanzen
 - Keine gemeinsamen Datenbanken zwischen Umgebungen
-

3. Authentifizierung und Autorisierung

3.1 Aktueller Stand

- **Mechanismus:** JSON Web Tokens (JWT)
- **Implementierung:** Token-basierte Authentifizierung über Express-Middleware
- **Token-Verwaltung:** Manuelle Invalidierung im 2-Wochen-Rhythmus (Testphase)

3.2 Bekannte Schwachstellen und Maßnahmen

JWT-Lifetime:

- Aktuelle Konfiguration: zu prüfen und auf ≤ 15 Minuten (Access Token) zu reduzieren
- Refresh-Token-Rotation: geplant vor Go-Live

Token-Revocation:

- Sofortige Invalidierung einzelner Tokens bei Kompromittierung aktuell nicht möglich
- **Geplante Maßnahme:** Token-Blocklist in Redis oder DB-gestützte Session-Tabelle

Autorisierung:

- Rollenbasiertes Zugriffsmodell (RBAC) implementiert
- Admin-Aktionen werden geloggt (siehe Abschnitt 5)

3.3 Passwortrichtlinie

- Mindestlänge: 12 Zeichen
 - Komplexitätsanforderungen: Groß-/Kleinbuchstaben, Ziffern, Sonderzeichen
 - Passwort-Hashing: bcrypt (Faktor ≥ 12)
 - Multi-Faktor-Authentifizierung: **geplant** (Phase 2)
-

4. Netzwerk- und Transportsicherheit

4.1 Verschlüsselung

- Alle Verbindungen ausschließlich über HTTPS (TLS)
- Zertifikate via Let's Encrypt, automatische Erneuerung durch Caddy
- HTTP-zu-HTTPS-Weiterleitung aktiv
- Interne Kommunikation (Docker-Netzwerk) über isoliertes Bridge-Netzwerk

4.2 Rate Limiting

- **Status: Nicht implementiert (kritische Lücke)**

- **Geplante Maßnahme vor Go-Live:**

- Login-Endpoint: max. 5 Versuche / Minute pro IP
- API-Endpoints allgemein: max. 100 Requests / Minute pro Authenticated User
- Implementierung via `express-rate-limit` oder Caddy-Plugin

4.3 Firewall und Exposition

- Hetzner-Server: nur Ports 80 und 443 öffentlich exponiert
- Datenbankport (5432) nicht öffentlich erreichbar
- Docker-interne Ports nicht nach außen gemappt

5. Audit-Logging

5.1 Was wird geloggt

- Alle Login-Versuche (erfolgreich und fehlgeschlagen)
- Logout-Ereignisse
- Erstellung, Änderung und Löschung von EHS-Dokumenten
- Statusänderungen (z.B. Freigabe von Prüfprotokollen)
- Admin-Aktionen (User-Verwaltung, Rechtevergabe)
- Fehlgeschlagene Autorisierungsversuche (403-Responses)

5.2 Technische Umsetzung

- **Speicherort:** PostgreSQL-Tabellen in der Hauptdatenbank
- **Bekannte Schwachstelle:** Logs und Nutzdaten teilen dieselbe Datenbank. Ein Angreifer mit DB-Zugriff könnte theoretisch beide manipulieren.
- **Geplante Maßnahme:** Separate Log-Datenbank oder append-only Tabellen mit eingeschränkten DB-User-Rechten (nur INSERT, kein UPDATE/DELETE auf Log-Tabellen)

5.3 Aufbewahrung

- Aufbewahrungsdauer: mindestens 2 Jahre (ArG-Konformität)
- Löschung: nur durch expliziten Admin-Prozess, nicht durch Applikation

5.4 Auswertung

- Manuelle Auswertung bei Bedarf (aktuell)
- **Geplant:** Automatisches Alerting bei auffälligen Mustern (z.B. >10 fehlgeschlagene Logins in 5 Minuten)

6. Datenschutz und Compliance

6.1 Rechtsgrundlagen

- **Schweizer Datenschutzgesetz (nDSG)** – gilt für alle Schweizer Mandanten
- **DSGVO** – gilt für deutsche Mandanten (Aquist Deutschland GmbH)
- **ArG (Arbeitsgesetz Schweiz)** – Nachweispflicht für EHS-Dokumente

6.2 Datenverarbeitung

- Personenbezogene Daten: Namen, Rollen, Aktivitätsprotokolle der Mitarbeitenden
- Besondere Kategorien: Unfallberichte können Gesundheitsdaten enthalten
- Verarbeitungsverzeichnis: **in Erstellung**

6.3 Datenspeicherung

- Produktionsdaten: Hetzner-Server (Standort: Deutschland/Schweiz)
- Keine Weitergabe an Dritte ohne Rechtsgrundlage
- Backups: verschlüsselt, Aufbewahrung gemäß gesetzlicher Anforderungen

7. Integrität von EHS-Dokumenten

Da cflux ArG-relevante Nachweise verwaltet, gilt für abgeschlossene Dokumente:

- **Schreibschutz nach Freigabe:** freigegebene Dokumente dürfen nicht mehr editiert werden (technisch erzwungen, nicht nur organisatorisch)
- **Versionierung:** jede Änderung vor Freigabe wird versioniert gespeichert
- **Unveränderlichkeit:** abgeschlossene Prüfprotokolle, LOTOTO-Nachweise und Gefährdungsbeurteilungen sind im System als read-only markiert
- **Audit-Trail:** jeder Zugriff auf abgeschlossene Dokumente wird geloggt

Hinweis: Die technische Erzwingung des Schreibschutzes ist ein kritisches Sicherheitsmerkmal für die ArG-Compliance und muss vor Go-Live verifiziert werden.

8. Penetrationstests und Schwachstellenmanagement

8.1 Durchgeführte Tests

- OWASP ZAP automatischer Scan (Datum: Q4 2025)
- Ergebnis: kritische Findings behoben, Details intern dokumentiert

8.2 Bekannte offene Punkte

Punkt	Risiko	Geplante Maßnahme	Frist
Kein Rate Limiting	Hoch	express-rate-limit implementieren	Vor Go-Live
JWT-Lifetime unklar	Mittel	Token-Lifecycle definieren und umsetzen	Vor Go-Live
Logs in Haupt-DB	Mittel	Append-only / separate DB	Phase 2
Kein MFA	Mittel	OAuth2/MFA Integration	Phase 2
Token-Revocation	Mittel	Session-Tabelle oder Blocklist	Phase 2

8.3 Dependency-Management

- `npm audit` regelmäßig vor Releases

- Abhängigkeiten mit bekannten CVEs werden zeitnah aktualisiert
 - Geplant: automatisierter Dependency-Scan im CI/CD-Prozess
-

9. Infrastruktur und Betrieb

9.1 Serverhärtung

- Betriebssystem: aktuell gepatcht
- SSH: nur Key-basierter Zugriff, Root-Login deaktiviert
- Nicht benötigte Dienste: deaktiviert

9.2 Backup-Strategie

- Datenbankbackups: täglich (Cronjob), verschlüsselt
- Aufbewahrung: 30 Tage rolling
- Wiederherstellungstest: **geplant** (quartalsweise)

9.3 Umgebungstrennung

- Produktions- und Testumgebung sind physisch getrennte Docker-Instanzen
 - Kein Zugriff der Testumgebung auf Produktionsdaten
 - Separate Zugangsdaten für beide Umgebungen
-

10. Verantwortlichkeiten

Bereich	Verantwortlich
Technische Sicherheit (cflux)	Matthias Püschi
Datenschutz / DSGVO	Philipp Amacker
Freigabe Sicherheitskonzept	?
Notfallkontakt bei Sicherheitsvorfall	Matthias Püschi

11. Notfallplan (Incident Response)

Im Fall eines Sicherheitsvorfalls:

1. **Erkennung:** Meldung an Matthias Püschi
 2. **Eindämmung:** betroffene Dienste isolieren (Docker-Container stoppen)
 3. **Analyse:** Logs sichern, Angriffsvektor identifizieren
 4. **Benachrichtigung:** Frank informieren; bei Datenschutzverletzung Meldepflicht binnen 72h (DSGVO/nDSG) prüfen
 5. **Wiederherstellung:** aus Backup, nach Behebung der Schwachstelle
 6. **Dokumentation:** Vorfall und Maßnahmen schriftlich festhalten
-

12. Revisionshistorie

Version	Datum	Änderung	Autor
1.0	März 2026	Erstfassung	M. Püski

Dieses Dokument ist ein lebendiges Dokument und wird mit dem Fortschritt der cflux-Entwicklung aktualisiert.